

Academic Year	Module	Assessment Number	Assessment Type
2025	Professionalism Assessment	1	Report

AI-Powered Phishing Detection System

Student: Bipin Khanal

University id :2407713

Supervisor: Sangay lama

Reader: Subash Bista

Contents

1. INTRODUCTION	3
2. SOCIAL IMPACT	4
3. ETHICAL CONSIDERATIONS	5
4. LEGAL IMPLICATIONS.....	6
5. SECURITY CONSIDERATIONS.....	7
6. Conclusion.....	8
REFERENCES	9

1. INTRODUCTION

Phishing attacks remain a serious problem because they target both technology and human behaviour. Attackers often design emails to look familiar, urgent, or trustworthy so that users click links, reveal credentials, or share sensitive information before thinking carefully. This project responds to that problem by developing an AI-powered phishing detection prototype that uses a Mailhook/webhook pipeline, backend analysis, machine learning, heuristic checks, and a Flutter interface to show users whether an email appears safe or hazardous.

The professionalism issues in this project are important because the system handles email content, which may contain personal or sensitive data. The project therefore raises social, ethical, legal, and security concerns. These include user safety, privacy, transparency, false positives, backend trust, data protection, and secure handling of stored email records. Phishing attacks often use social engineering and psychological pressure, so a responsible detection system should not only classify risk but also explain why a message looks suspicious (Alkhalil et al., 2021; Chanti and Chithralekha, 2020).

2. SOCIAL IMPACT

The main social benefit of this project is that it can help users recognise suspicious emails before they click a harmful link or trust a fake message. Phishing can cause financial loss, account compromise, identity theft, stress, and confusion, especially for users who are less confident with technology. By showing a risk score and explanation, the system supports safer decision-making instead of simply giving a hidden “block” or “allow” result.

The project may have positive social impact in several ways:

- It gives users early warning about suspicious emails.
- It separates safe emails from hazardous or quarantined emails.
- It explains warning signs such as suspicious URLs, urgency language, threat wording, and possible brand impersonation.
- It can improve user awareness over time because users can see why a message was flagged.
- It supports human review through retest and migrate-to-safe functions.

There are also possible negative impacts. A safe email may sometimes be wrongly flagged as hazardous, which can confuse users or reduce trust in the system. On the other hand, a phishing email may occasionally be missed. For that reason, the system should be presented as a support tool rather than a perfect replacement for user judgement. Research on phishing shows that attackers often rely on social engineering and user pressure, so improving awareness is an important part of reducing phishing risk (Alkhalil et al., 2021; Chanti and Chithralekha, 2020).

3. ETHICAL CONSIDERATIONS

Ethical issues are important in this project because the system analyses email content, and emails can contain private or sensitive information. In the final implementation, email data is received through the Mailhook/webhook pipeline and processed by the controlled backend. This means the backend is a sensitive trust boundary and must be handled responsibly.

The main ethical considerations are:

- **Privacy:** email content should only be used for phishing analysis.
- **Transparency:** users should be shown clear reasons for a classification.
- **User control:** the system should support review rather than forcing blind acceptance of the result.
- **Fairness:** the model should be evaluated carefully because biased or limited training data can affect predictions.
- **Accuracy limits:** the system should not claim perfect detection because false positives and false negatives can still happen.

The project addresses these issues by showing risk scores and explanations instead of only displaying a final label. This is important because users need to understand why an email was marked safe or hazardous. The system also includes retesting and migrate-to-safe functionality, which gives users a way to review uncertain results. NLP and machine learning can support phishing detection, but they still need careful evaluation and human-facing explanations (Vazquez, Iglesias and Zseby, 2020; Sahingoz et al., 2019).

4. LEGAL IMPLICATIONS

Legal responsibility is important because the project handles email content, which may include personal data. Under UK GDPR principles, personal data should be processed lawfully, fairly and transparently, collected for a specific purpose, limited to what is necessary, kept only as long as needed, and protected with appropriate security measures.

For this project, the main legal implications are:

- Email data should only be processed for phishing detection.
- Users should understand how their email content is handled.
- Stored records should be protected from unauthorised access.
- Data should not be retained longer than necessary.
- A production version would need clearer consent, privacy notices, secure storage, and access control.

The final prototype does not use Gmail or Outlook OAuth as the main implementation. Instead, it uses a Mailhook/webhook pipeline and controlled backend. This reduces the complexity of provider login and token handling, but it does not remove legal responsibility because webhook-ingested emails still pass through the backend. If the system were deployed beyond a prototype, stronger data protection controls would be required.

There is also a broader cybersecurity law issue. The UK Computer Misuse Act 1990 deals with unauthorised access to computer material and related misuse of systems. For this project, this means the tool should be used only for defensive phishing detection and should not be modified or used to access accounts, systems, or data without permission

5. SECURITY CONSIDERATIONS

Security is central to this project because the system receives and stores email-related data. In the final implementation, email data is analysed through the backend and optional Python ML service, then stored as JSON records. This means the backend, webhook route, model service, and storage folder must be treated as sensitive parts of the system.

The main security considerations are:

- The webhook endpoint should only accept trusted input in a production version.
- HTTPS should be used for communication outside local testing.
- API keys and secrets should be kept in environment files and not exposed in code.
- Stored JSON email records should be protected from unauthorised access.
- Webhook signature verification should be added for production use.
- Old or unnecessary email records should be deleted according to a retention policy.
- The system should handle invalid email data safely.

The current prototype is suitable for demonstrating the phishing detection workflow, but it is not a full commercial email security gateway. A production version would need stronger authentication, access control, secure database storage, logging, monitoring, and regular model updates. This is especially important because phishing methods change over time and detection systems must be maintained to remain useful (Sahingoz et al., 2019; Chanti and Chithralekha, 2020).

6. Conclusion

This professionalism assessment shows that the phishing detection project involves more than technical implementation. The system has clear social value because it can help users recognise suspicious emails and understand common phishing warning signs. At the same time, it raises ethical, legal, and security responsibilities because email data may contain sensitive information.

The final system uses a Mailhook/webhook pipeline, backend analysis, machine learning, heuristic checks, JSON storage, and a Flutter interface. Because webhook-ingested emails pass through the backend, privacy and security must be taken seriously. The project addresses this through risk scores, explanations, retesting, and user-facing warnings, but a production version would still require stronger data protection, secure storage, authentication, HTTPS, webhook verification, and clear privacy controls.

REFERENCES

Alkhalil, Z., Hewage, C., Nawaf, L. and Khan, I. (2021) ‘Phishing attacks: a recent comprehensive study and a new anatomy’, *Frontiers in Computer Science*, 3, Article 563060. doi: 10.3389/fcomp.2021.563060.

Chanti, S. and Chithralekha, T. (2020) ‘A survey on phishing attack detection and prevention’, in *Proceedings of the International Conference on Innovative Computing and Communications (ICICC)*. Singapore: Springer.

Sahingoz, O.K., Buber, E., Demir, O. and Diri, B. (2019) ‘Machine learning based phishing detection from URLs’, *Expert Systems with Applications*, 117, pp. 345–357. doi: 10.1016/j.eswa.2018.09.029.

Vazquez, D., Iglesias, F. and Zseby, T. (2020) ‘A natural language processing-based approach to phishing detection’, in *Proceedings of the IEEE International Conference on Communications Workshops (ICC Workshops)*. IEEE.

Information Commissioner’s Office (ICO) (2025) *Principles*. Available at: <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/data-protection-principles/a-guide-to-the-data-protection-principles/the-principles/> (Accessed: 19 May 2026).

UK Government (1990) *Computer Misuse Act 1990*. Available at: <https://www.legislation.gov.uk/ukpga/1990/18/contents> (Accessed: 19 May 2026).